

NMAP — Cheatsheet de Escaneos

Cada tarjeta = un tipo de escaneo. Lo que hace, como funciona, cuando usarlo, comando.

-sU UDP Scan

LENTO SIN HANDSHAKE SERVICIOS INTERMITENTES

Que hace: Escanea puertos UDP. UDP no tiene handshake como TCP. Nmap envia un paquete UDP y analiza la respuesta.

Como detecta el estado:

No responde open|filtered
ICMP port unreachable closed
Responde con UDP open

Si mandas UDP al puerto 22 (SSH/TCP):

SSH escucha solo TCP. Si mandas UDP al puerto 22, nadie esta escuchando UDP ahi. El kernel responde ICMP port unreachable. Nmap lo marca como closed. UDP y TCP son protocolos separados. El OS los gestiona de forma independiente.

Por que es tan lento:

Linux limita las respuestas ICMP a 1 por segundo (RFC 1812). 65535 puertos UDP = aproximadamente 18 horas en el peor caso. Siempre usar con -top-ports.

Puertos UDP mas importantes:

53 DNS 67 DHCP 69 TFTP 123 NTP
161 SNMP 500 IKE (VPN IPSec)

```
nmap -sU --top-ports 100 192.168.1.1
nmap -sS -sU -p T:80,443,U:53,161 IP
```

-Pn Skip Host Discovery

SIN PING PREVIO FUERZA ESCANEO

Que hace: Desactiva el host discovery previo y asume que el host esta activo sin comprobarlo.

El proceso normal SIN -Pn:

1. nmap envia ICMP echo request (ping)
2. Si no responde → asume host muerto → no escanea nada
3. Si responde → procede a escanear puertos

CON -Pn: Se salta el ping y escanea directamente.

Cuando usarlo:

- Firewall que bloquea ICMP
- Windows: bloquea ICMP por defecto
- Servidores cloud: AWS, Azure, GCP
- Hosts con IDS que ignoran ICMP

Sin -Pn obtendrias un falso negativo: nmap diria que el host esta muerto cuando en realidad esta vivo y corriendo servicios.

```
nmap -sS -Pn 192.168.1.1
nmap -sS -sV -Pn -n -p- 192.168.1.1
```

-sn Ping Scan

SOLO HOSTS ACTIVOS SIN PUERTOS

Que hace: Solo detecta que hosts estan activos en una red. No escanea ningun puerto.

En red local (LAN):

Usa ARP requests (capa 2). ARP es muy confiable porque opera por debajo de IP. Practicamente imposible de bloquear en una red local. Resultado: muy preciso.

En servidor remoto (internet):

No puede usar ARP. Usa:

- ICMP echo request (ping)
- TCP SYN al puerto 443
- TCP ACK al puerto 80

Si el servidor bloquea todo esto → falso negativo. Combinar con -Pn para forzar escaneo de puertos directamente.

```
nmap -sn 192.168.1.0/24
nmap -sn 192.168.1.1-254
nmap -sn 10.0.0.0/8
```

-sA ACK Scan

DETECTA FIREWALL NO PUERTOS ABIERTO

Que hace: NO detecta puertos abiertos o cerrados. Detecta si hay un firewall y que puertos filtra.

Como funciona:

Envia un paquete TCP con el flag ACK activado sin haber enviado SYN antes.

Recibe **RST** **unfiltered**: sin firewall
No responde **filtered**: firewall bloqueando

Por que un ACK sin SYN revela el firewall:

Una conexi3n normal es SYN → SYN/ACK → ACK. Si mandas ACK sin SYN previo:

- Sin firewall: kernel recibe ACK inesperado → RST
- Con firewall stateful: descarta el paquete → silencio

Para que sirve en hacking:

- Mapear exactamente que puertos filtra el firewall
- Distinguir firewall stateful de stateless
- Encontrar puertos no filtrados para usarlos como vector
- Entender la arquitectura defensiva antes de atacar

```
nmap -sA 192.168.1.1
nmap -sA -p 80,443,22,8080 192.168.1.1
```

-sC Default Scripts (NSE)

SCRIPTS AUTOMATICOS INFO EXTRA

Que hace: Ejecuta scripts de la categoria **default** del NSE (Nmap Scripting Engine). Solo scripts seguros, se ejecutan segun el servicio detectado en cada puerto.

Scripts por servicio:

Puerto	Que hace
22 SSH	claves publicas RSA, ECDSA del servidor
80/443	titulo web, version del servidor
21 FTP	detecta login anonimo sin contrasena
445 SMB	detecta OS, configuracion de seguridad
3306	version MySQL, acceso sin contrasena
25 SMTP	comandos disponibles, open relay

Output tipico:

```
22/tcp open ssh
| ssh-hostkey: 2048 ab:cd (RSA)
80/tcp open http
|_http-title: Apache2 Default Page
21/tcp open ftp
|_ftp-anon: Anonymous FTP login allowed
```

```
nmap -sC -sV 192.168.1.1
nmap -A 192.168.1.1 # = -sC -sV -O
```

-sN / -sF / -sX Escaneos Sigilosos

RFC 793 NO EN WINDOWS EVADE FIREWALLS

Base teorica RFC 793:

Puerto **abierto** + paquete sin SYN/ACK/RST → **silencio**

Puerto **cerrado** + paquete sin SYN/ACK/RST → **RST**

Flag	Envia	Uso
-sN NULL	ninguno	maximo sigilo
-sF FIN	FIN	alto sigilo
-sX Xmas	FIN+PSH+URG	alto sigilo

Por que evaden firewalls:

Firewalls stateless solo inspeccionan SYN. Un paquete NULL, FIN o Xmas no tiene SYN, puede pasar sin ser inspeccionado.

Problema critico con Windows:

Windows no sigue RFC 793. Responde RST en puertos abiertos Y cerrados. No funciona en Windows. Solo Linux, Unix y macOS.

Escaneo	Linux abierto	Windows abierto
-sN/-sF/-sX	silencio	RST (igual que cerrado)

```
nmap -sN 192.168.1.1
nmap -sF 192.168.1.1
nmap -sX -T1 -n -Pn 192.168.1.1
```

-sO Protocol Scan

CAPA 3 NO ES ESCANEEO DE PUERTOS

Que hace: No escanea puertos TCP ni UDP. Escanea que protocolos IP soporta el host a nivel de capa 3, modificando el campo *protocol* del header IP.

Como funciona:

Cualquier respuesta o silencio **open|filtered**
ICMP protocol unreachable **closed**

Protocolos que detecta:

N	Protocolo	Que indica
1	ICMP	mensajes de control (ping)
6	TCP	transporte confiable
17	UDP	transporte sin conexion
47	GRE	tunneling VPN PPTP
50	ESP	IPSec cifrado
51	AH	IPSec autenticacion
89	OSPF	protocolo de enrutamiento

Para que sirve en hacking:

- GRE, ESP o AH activos → el host tiene VPN
- Encontrar protocolos que el IDS no inspecciona
- Usarlos como canal para evadir deteccion

```
nmap -sO -v 192.168.1.1
```

Respuestas TCP — Lo esencial

SYN/ACK **puerto ABIERTO**
RST/ACK **puerto CERRADO**
silencio **FILTRADO por firewall**

-sS SYN scan (el mas usado):

SYN → SYN/ACK → RST (no completa)

Requiere root. El mas silencioso.

-sT TCP connect:

Completa el handshake completo.

Deja logs en el servidor. No requiere root.

Combinaciones en Hacking

```
# escaneo completo estandar
nmap -sS -sV -sC -O -p- -T4 IP

# host no responde ping
nmap -sS -Pn -sV -p- IP

# descubrir red completa
nmap -sn 192.168.1.0/24

# sigiloso y completo
nmap -sS -sV -Pn -n -T2 -p- IP

# mapear firewall primero
nmap -sA -p 80,443,22,8080 IP

# buscar vulnerabilidades
nmap -sV --script=vuln IP

# evasion maxima
nmap -sX -T1 -n -Pn IP

# UDP servicios criticos
nmap -sU --top-ports 100 IP
```

REGLAS DE ORO: Siempre 2>/dev/null para descartar errores de permisos | -T1 para sigilo real | -T4 para CTFs y laboratorios | -p- para escanear todos los 65535 puertos | -n para no resolver DNS y no dejar rastro